

DEN/CYBER-EUS-0018: Cybersecurity requirements for software that searches for, removes, or quarantines malicious software. Deep Dive Session

Presented by:

Pol Alemany

Centre Tecnològic de Telecomunicacions de
Catalunya (CTTC/CERCA)

EN 304 619

22/01/2026



Agenda

CRA & Standardization Request Overview

STAN4CR2 Project Context & Support

Draft Standard Key Objectives

The Draft:

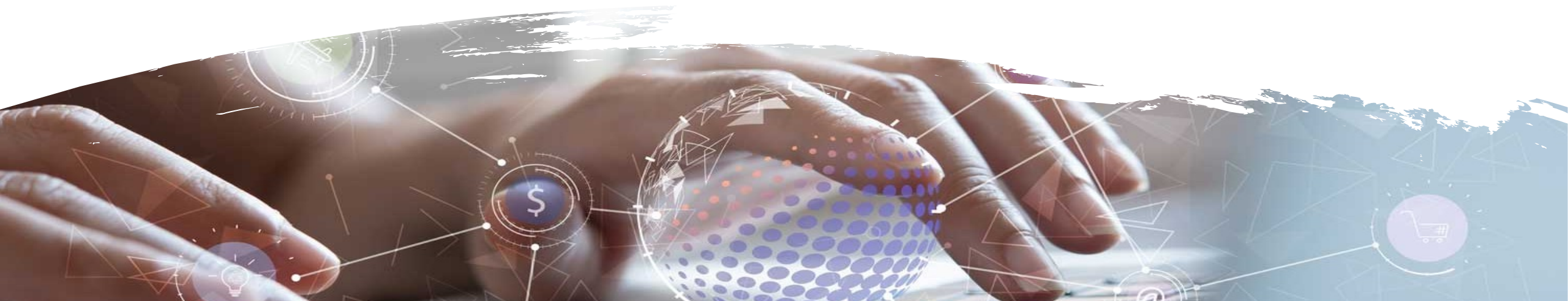
- Clause 4 – Product Context

- Clause 5 – Security Requirements

- Clause 6 – Security Requirements Assessment

- Annexes

Challenges & Collaboration to Solve Them



CRA & Standardization Request Overview

Cyber Resilience Act Purpose

CRA ensures products with digital elements are secure by design and resilient against cyber threats throughout their lifecycle.

Obligations and Focus Areas

CRA mandates manufacturers, importers, and distributors to focus on vulnerability management, secure updates, and transparency.

Standardization Request Role

European Commission requested ETSI, CEN, and CENELEC to develop harmonized standards supporting voluntary CRA compliance.

Harmonized Standards Benefits

Harmonized standards reduce market fragmentation and help manufacturers efficiently meet regulatory expectations across the EU.

EN

OJ L, 20.11.2024

ANNEX I

ESSENTIAL CYBERSECURITY REQUIREMENTS

Part I Cybersecurity requirements relating to the properties of products with digital elements

- (1) Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.
- (2) On the basis of the cybersecurity risk assessment referred to in Article 13(2) and where applicable, products with digital elements shall:
 - (a) be made available on the market without known exploitable vulnerabilities;
 - (b) be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state;
 - (c) ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them;
 - (d) ensure protection from unauthorized access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorized access;
 - (e) protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means;
 - (f) protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorized by the user, and report on corruptions;
 - (g) process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation);
 - (h) protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks;
 - (i) minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks;
 - (j) be designed, developed and produced to limit attack surfaces, including external interfaces;
 - (k) be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques;
 - (l) provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user;
 - (m) provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.

Part II Vulnerability handling requirements

Manufacturers of products with digital elements shall:

- (1) identify and document vulnerabilities and components contained in products with digital elements, including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very least the top-level dependencies of the products;

68/81

ELI: <http://data.europa.eu/eli/reg/2024/2847/oj>

STAN4CR2 Project Context & Support

Harmonized Standards Development

STAN4CR2 focuses on creating multiple cybersecurity standards for different vertical products with digital elements to ensure CRA compliance.

Organizational Leadership and Funding

ETSI leads the project through the TC CYBER with funding from the European Commission and the support from ENISA to ensure project success.

Collaborative Approach

The project fosters collaboration among industry, regulators, and academia to address cybersecurity challenges and align with EU regulations.

Impact on Product Design and Market Access

Standards developed will influence product certification and market access, promoting innovation and high security across Europe.

Draft Standard Key Objectives & Status

To place products securely on the market, the draft aims to provide:

- the set of minimum use cases in which the products (e.g., Antivirus) may belong.
- the risk analysis associated with the previous use cases and security requirements that the product should consider.
- the security requirements for the product.
- the assessment criteria associated with the product.

Currently accepted as **Mature draft** and sent to the EC for Harmonisation Assessment



The Draft

Clause 4 – Product Context

Clause 5 – Security Requirements

Clause 6 – Security Requirements Assessment

Annexes



Product Context (Clause 4)

Intended Purpose & Product Functions

Generic Product Architecture Overview & Operational Environment

Distribution of Security Functions & Users

Reasonably Foreseeable Use Cases



Intended Purpose & Product Functions

Purpose:

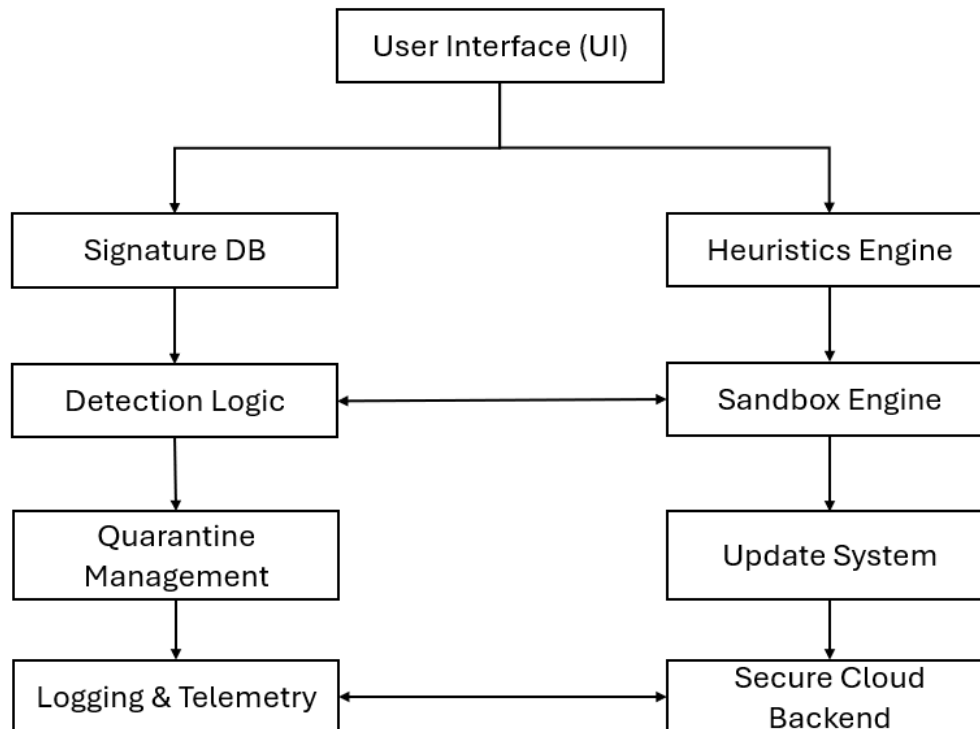
The draft does not substitute but complements the CRA with the main focus on **Antivirus/Antimalware**



Functions:

- **Virus Detection / Malware Detection** → Signature-based Detection / Behaviour-based Detection /Heuristics-based Detection
- **Threat Management** → Quarantine / Removal / Notification
- **Continuous Monitoring and Updates** → Product itself, new and emerging threats, threat signatures, behaviour models, and heuristic algorithms.

Generic Product Architecture Overview & Operational Environment



Logical Operational Environment → Key dependency on OSs.

Physical Operational Environment → Devices, Hardware specs., env. conditions, power supply.

Chain of Trust → Certification & compliance with trusted standards, root of trust for updates, transparency and provenance of the product, etc.

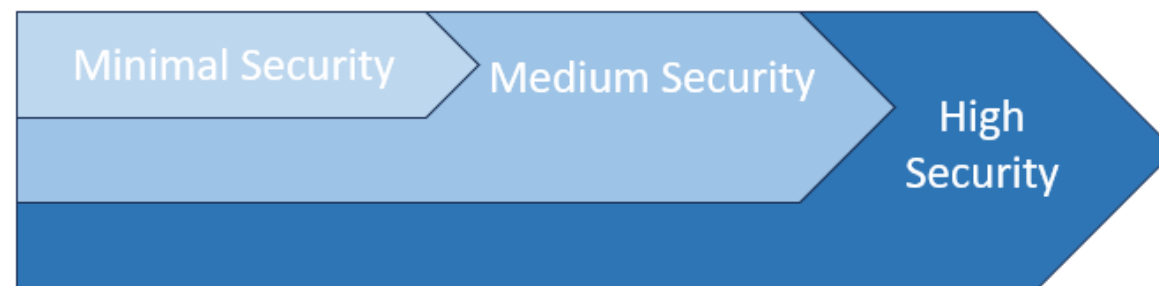
Zero Trust Guidelines → Based on ETSI TS 104 102 and ETSI TS 104 103.

Security Logging Guidelines → Authentication & Access, Authorization & Command, System Integrity & Boot Logging, etc.

Cryptography Guidelines → Objectives, standardized algorithms, cryptographic tools, specialised standards to be followed.

Distribution of Security Functions & Users

Security Category Class (SCC)



Users:

- **U1: Consumers** (Private Data on Personal Desktops and other wirelessly or wired connected smart devices)
- **U2: Enterprises** (Private Data on Enterprise Desktops, Laptops and other wirelessly or wired connected smart devices)
- **U3: Public Administration** (Private Data on Public-Entity-Owned Desktops, Laptops and other wirelessly or wired connected smart devices)

Reasonably Foreseeable Use Cases

Users:

- **UC1 - Consumer Environments:** “...a protected system is used for everyday productivity and personal tasks on mainstream operating systems and hardware for the U1 category of users...”
- **UC2 - Small-Midsize Enterprise Environments:** “...a protected system needs to handle sensitive data and safety-critical processes, but the protected systems are used by non-expert cybersecurity users...”
- **UC3 - Large Enterprise Environments:** “... refers to the U2 and U3 categories of users working for large enterprise environments, such as financial institutions, retail, and various educational institutions ...”
- **UC4 – Critical Infrastructure Environments:** “... refers to the U2 and U3 categories of users working for private or public organizations responsible for critical infrastructure environments, such as utilities, health care organizations, and service providers ...”

UC	Users Involved (Clause 4.6)	Computed Overall SCC (Annex C)	SCC (Clause 4.5)
UC1	U1	1,944	Medium
UC2	U2	2,111	High
UC3	U2, U3	2,055	High
UC4	U2, U3	2,222	High

Requirements Specifications (Clause 5)

Security Requirements
Vulnerability Handling Requirements
Requirements & SCC Mapping



Security Requirements

A total set of 46 security requirements classified



Security by Default Configuration (6)

Security updates (4)

Authentication and Access Control (7)

Confidentiality Protection (4)

Integrity Protection (4)

Data Minimization (3)

Availability Protection (2)

Impact Minimization (1)

Secure by Design (6)

Exploitation Mitigation Mechanisms and Techniques (2)

Logging and Monitoring Mechanisms (6)

Data Removal and Transference Mechanisms (1)

Vulnerability Handling Requirements

A set of 7 requirements is proposed but... it is a complex topic!!!

Further discussion is required:

- Do the proposed requirements fit for the product context?
- Shall the standard relay only on prEN 40000-1-3??

prEN 40000-1-3: "Cybersecurity requirements for products with digital elements – Vulnerability Handling" [Version and date to be added upon its publication by CEN CENELEC]"

Requirements & SCC Mapping

Example: Secure by Default Configuration Requiriements

Requirements	UCs				SCCs		
	UC1	UC2	UC3	UC4	Minimal	Medium	High
REQ-SDC-01	X	X	X	X	X		
REQ-SDC-02	X	X	X	X	X		
REQ-SDC-03	X	X	X	X	X		
REQ-SDC-04	X	X	X	X	X		
REQ-SDC-05		X	X	X			X
REQ-SDC-06	X	X	X	X		X	

Requirements Assessment (Clause 6)

Security Requirements
Vulnerability Handling Requirements



Security Requirements Assessment

Assessment Objective: Defines the security property or capability that shall be verified.

Assessment Preparation: The environment, setup, and preconditions required before executing tests.

- Test environment
- Preconditions
- Required tools
- References (if necessary)

Assessment Activities: Tests execution steps to be performed such as documentation review, security functional or penetration tests, code or binaries analysis, configurations inspection and/or runtime behaviour observation.

Assignment of Verdict: Defines the pass/fail criteria.

Supporting Evidence: Defines the artefacts and documentation that shall be collected to demonstrate that the requirement has been assessed and fulfilled:

- Test or assessment reports
- Logs, configuration files, or audit traces
- Screenshots, captures, or console outputs
- Relevant vendor or design documentation

Vulnerability Handling Requirements Assessment

Due to the dependency with the same topic in Clause 5... further discussion is required:

- Do we apply the same structure as the security requirements?
- Shall the standard relay only on prEN 40000-1-3?? Or do AVs need a different text?
prEN 40000-1-3: “Cybersecurity requirements for products with digital elements – Vulnerability Handling” [Version and date to be added upon its publication by CEN CENELEC]”

Annexes

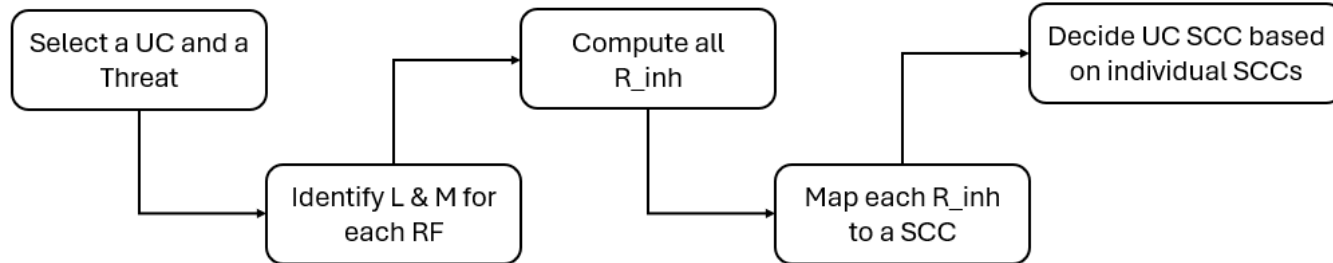
- A – Draft and EU Regulation 2024/2847 (CRA) Relationship**
- B – Methodology for the Assessment of Cybersecurity Risks**
- C – Use Cases Risk Assessment**
- D – Identified Threats
- E – Identified Risk Factors
- F – Current Virus and Malware Examples
- G – Relationship with other ETSI standards



Annex A – Draft & EU Regulation 2024/2847 (CRA) Relationship

Harmonised Standard ETSI EN 304 619					
Requirement				Requirement Conditionality	
No	Description in EU 2024/2847 (i.1)	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
1	"Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks."	Annex I, Part I, (1)	Clauses 5 and 6 implement a risk-based approach through scaled requirements	U	
2	"Products with digital elements shall be made available on the market without known exploitable vulnerabilities."	Annex I, Part I, (2)(a)	Clause 5.3	U	
3	"Products with digital elements shall be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state."	Annex I, Part I, (2)(b)	Clause 5.2.2	U	
4	"Products with digital elements shall ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them."	Annex I, Part I, (2)(c)	Clause 5.2.3	U	
5	"Products with digital elements shall ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access"	Annex I, Part I, (2)(d)	Clause 5.2.4	U	
6	"Products with digital elements shall protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by best practice mechanisms, and by using other technical means."	Annex I, Part I, (2)(e)	Clause 5.2.5	U	
7	"Products with digital elements shall protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions."	Annex I, Part I, (2)(f)	Clause 5.2.6	U	
8	"Products with digital elements shall process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation)."	Annex I, Part I, (2)(g)	Clause 5.2.7	U	
9	"Products with digital elements shall protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks."	Annex I, Part I, (2)(h)	Clause 5.2.8	U	
10	"Products with digital elements shall minimise the negative impact by the products themselves or connected products on the availability of services provided by other products or networks."	Annex I, Part I, (2)(i)	Clause 5.2.9	U	
11	"Products with digital elements shall be designed, developed and produced to limit attack surfaces, including external interfaces."	Annex I, Part I, (2)(j)	Clause 5.2.10	U	
12	"Products with digital elements shall be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques."	Annex I, Part I, (2)(k)	Clause 5.11	U	
13	"Products with digital elements shall provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user."	Annex I, Part I, (2)(l)	Clause 5.2.12	U	
14	"Products with digital elements shall provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner."	Annex I, Part I, (2)(m)	Clause 5.2.13	U	

Annex B – Methodology for the Assessment of Cybersecurity Risks



Category	Description (indicative frequency)*	Value
Rare	Threat requires multiple preconditions; strong controls; limited exposure.	1
Unlikely	Feasible but constrained by environment or controls.	2
Possible	Routinely observed in similar deployments.	3
Likely	Common in sector; known active adversaries.	4
Almost certain	Continuously attempted in large populations.	5

Category	Illustrative consequence for product / environment	Value
Negligible	No data/ops impact and no material loss; transient, auto-recoverable.	1
Minor	Localized user disruption; recoverable quickly; user inconvenience; no data at risk	2
Moderate	Service interruption or privacy event requiring incident handling	3
Major	Material service outage, significant data exposure, or regulatory notification, quarantines/updates disabled.	4
Severe	Safety/public-service impact, widespread outage, or large-scale data compromise; legal/reporting impact.	5

L	RFL 1	RFL 2	RFL 3	RFL 4	RFL 5	RFL 6	RFL 7	Mean RFL	Final L (rounded Mean RLF)
	3	3	4	4	3	4	3	3,43	3
M	RFM 1	RFM 2	RFM 3	RFM 4	RFM 5	RFM 6	RFM 7	Mean RFM	Final M (rounded Mean RLM)
	4	4	5	4	4	3	3	3,86	4

Scenario: UC2 – Small-Midsize Enterprise Environments.

Threat: TH-D1.2: Compromised Update Packages.

Components: Update System, Signature DB, Secure Communications

Computed values:

- L & M Identification
- Inherent risk: $R_{inh} = 3 \times 4 = 12$
- Individual SCC identification: 12 → TH-D1.2 in UC2 requires **Medium Security**.

Overall SCC identification:

- The previous step needs to be applied to all the identified threats (Annex D) to compute the overall SCC value:
 - Individual SCC mapping to numerical values: Minimal (1), Medium (2), High (3)
 - *Overall SCC = Sum of all Individual SCCs / Total number of threats in Annex D*
 - Final overall SCC decision:
 - 0 – 1 (Minimal SCC)
 - 1,01 – 2,0 (Medium SCC)
 - 2,01 – 3 (High SCC).

Annex C – Use Cases Risk Assessment: UC2 Example

	L	M	R_inh	Individual SCC	Overall SCC
TH-D1.1	3	3	9	Medium (2)	High (2,111)
TH-D1.2	3	4	12	Medium (2)	
TH-D1.3	3	3	9	Medium (2)	
TH-D2.1	4	4	16	High (3)	
TH-D2.2	3	2	6	Medium (2)	
TH-D2.3	3	4	12	Medium (2)	
TH-D3.1	3	3	9	Medium (2)	
TH-D3.2	3	3	9	Medium (2)	
TH-D3.3	3	4	12	Medium (2)	
TH-D4.1	3	4	12	Medium (2)	
TH-D4.2	3	5	15	Medium (2)	
TH-D4.3	2	3	6	Medium (2)	
TH-D5.1	3	5	15	Medium (2)	
TH-D5.2	4	4	16	High (3)	
TH-D5.3	2	5	10	Medium (2)	
TH-D6.1	3	3	9	Medium (2)	
TH-D6.2	4	3	12	Medium (2)	
TH-D6.3	3	2	6	Medium (2)	

Challenges & Collaboration to solve them

Antivirus/Antimalware Vertical Challenges

Your Opinion/Expertise is Key

How to participate??



ANTIVIRUS/ANTIMALWARE Vertical: Challenges

Challenge 1 – Can we improve the current content? How??

More users? More UCs?

Challenge 2 – Vulnerability Handling Requirements

Currently depending on prEN 40000-1-3, should we depend on it or does AV need specific requirements?

Challenge 3 – Requirements & SCC Mapping

Are there all the requirements assigned to the right SCC? Should a req be upgraded downgraded?

Challenge 4 – UCs risk assessment

Are the proposed values coherent? Other possibilities?

Challenge 5 – Cross-vertical Topics

RDPS, Cryptography, Secure Updates, SBOM, Vulnerability Handling, Authentication, Logging.

YOUR OPINION/EXPERTISE IS KEY!!

Importance of Stakeholder Feedback

Active feedback ensures the draft standard aligns with industry needs and regulatory expectations.

Areas Needing Feedback

NO clause is written in stone, and they all may be improved.

Collaborative Submission Process

Comments submitted via collaborative platforms ensure transparency and traceability of contributions. → Open Consultations & Open Enquiry (Jan-Mar '26)

Impact on Cybersecurity Standards

Engagement shapes harmonized standards influencing antivirus and antimalware cybersecurity practices.



HOW TO PARTICIPATE??

Access Draft Documents

ETSI Open Area provides public access to draft documents for review and commenting by diverse stakeholders.

→ <https://docbox.etsi.org/CYBER/EUSR/Open>

Collaborative Comments

ETSI Labs offers a space technical discussions to improve draft standards.

→ <https://labs.etsi.org/rep/stan4cra>

Active Stakeholder Engagement

Participants submit comments, propose improvements, and engage in debates to refine standards and methodologies.

Guidelines for Participation

Stakeholders register on platforms, access drafts, and follow comment submission guidelines to contribute effectively.



Q&A





Thank you for your attention!!

Contact: pol.alemany@cttc.cat



Co-funded by
the European Union

Follow us on:

